

USER LEVELS & ACCESS CONTROL MODEL

Asset Management Prioritisation Tool

1. Purpose of This Model

This access control model defines how users interact with the Asset Management Prioritisation Tool.

It ensures:

- Company data remains isolated
- Permissions are predictable and safe
- Users only see what they are authorised to see
- Private client groups remain protected
- The system can scale without redesigning access rules

This is not just RBAC — it is a **governance framework** designed for long-term growth.

2. Customer- Roles

Your system now supports **four** customer-facing roles.

2.1 Company Admin

The highest authority within a company group.

Capabilities

- Full control of users, assets, and issues
- Assign, complete, and delete issues

- View deleted issues
- Access all dashboard metrics
- Access mapping and priority insights
- Maintain company-level data integrity
- Manage private client groups

Purpose

To give each company full autonomy over its own data and operations.

2.2 Company User

The standard operational role.

Capabilities

- Create issues
- Update issues assigned to them
- View all assets and issues
- Access dashboard metrics
- Access mapping and priority insights

Purpose

To empower field teams, engineers, inspectors, and staff.

2.3 Single User

A specialised role designed for **private client groups**.

This role has **similar permissions to Company User**, but with **strict data isolation**.

Capabilities

- Create issues

- Update issues assigned to them
- View assets and issues **only within their Private Client Group**
- Access dashboard metrics (filtered to their group)
- Access mapping and priority insights (filtered to their group)

Unique Power

- **Private Client Group Isolation**

Single Users can only see data belonging to their assigned private group.

They cannot see company-wide assets or issues.

Purpose

To support external clients, subcontractors, or restricted teams who must only access a subset of company data.

2.4 Viewer — “The Observer”

A read-only role for oversight, auditing, and transparency.

Capabilities

- View all assets

- View all issues (except deleted ones)
- View dashboard metrics
- View mapping and priority insights

Purpose

To provide safe visibility without risking accidental changes.

3. Internal System Role (Not Customer-Facing)

3.1 App Admin — “The System Guardian”

This role is **not visible in the UI** and **not assignable by customers**.

Capabilities

- System-level maintenance
- Multi-tenant oversight
- Debugging and support
- Internal configuration

Purpose

To support the platform internally without exposing system-wide controls to customers.

4. Capability Matrix (Updated with Single User)

Feature	Company Admin	Company User	Single User	Viewer	App Admin (Internal)
View Dashboard	✓	✓	✓ (group-filtered)	✓	✓
View Assets	✓	✓	✓ (group-filtered)	✓	✓
Create Assets	✓	✗	✗	✗	✓
Edit Assets	✓	✗	✗	✗	✓
View Issues	✓	✓	✓ (group-filtered)	✓	✓
Create Issues	✓	✓	✓	✗	✓
Edit Issues	✓	Limited	Limited	✗	✓
Assign Issues	✓	✗	✗	✗	✓
Complete Issues	✓	Limited	Limited	✗	✓
Delete Issues	✓	✗	✗	✗	✓
View Deleted Issues	✓	✗	✗	✗	✓
Manage Users	✓	✗	✗	✗	✓
Mapping	✓	✓	✓ (group-filtered)	✓	✓
Top Priorities	✓	✓	✓ (group-filtered)	✓	✓

5. Access Philosophy

Your RBAC model is built on four principles:

1. Least Privilege

Users only receive the minimum access required.

2. Company Isolation

No user can ever see another company's data.

3. Private Client Group Isolation (New)

Single Users are restricted to their assigned private group.

4. Modular Scalability

New modules (Reports, Notifications, Lifecycle Tracking) can plug in without redesign.

6. Future Role Roadmap (Already Supported by Architecture)

- Asset Manager
- Issue Manager
- External Auditor
- Super Admin
- Automation Bot Role

Your system is ready for these roles without structural changes.

7. Why This RBAC Model Stands Out

Your access model is:

- Enterprise-grade
- Multi-tenant safe
- Private-group aware
- Auditable
- Modular
- Clear for clients
- Designed for future expansion